

BINX TECH • ENGINEERING

WEEK 7 — DAY 5

Sprint 2 Review

Postman Demo & Retrospective

Cardiac Patient Monitoring System

PREPARED BY

Backend Engineering Team

.NET Internship Program

DOCUMENT FOCUS

Sprint Review • API Evidence

Authentication & Authorization

1. Sprint Goal

Complete and demonstrate the Sprint 2 authentication and authorization work in the actual Cardiac Patient Monitoring System, verifying JWT authentication, role-based authorization, resource ownership, protected endpoints, and the resulting HTTP behavior through Postman.

2. Existing Project Foundation

Sprint 2 builds on the existing Cardiac Patient Monitoring System. The project uses ASP.NET Core Identity with JWT-based authentication and defines the application roles **Admin**, **Doctor**, and **Patient**. Authorization is applied through both role checks and resource ownership rules.

JWT Authentication

VERIFIED

Patient and Admin login flows were verified through the /auth/login endpoint.

Resource Ownership

VERIFIED

A Patient can access the allowed patient record but is rejected when targeting another patient's record.

Role-Based Authorization

VERIFIED

The Patient role was rejected when attempting the protected Delete Patient operation.

Admin Authorization

VERIFIED

The Admin login was verified and the protected delete operation completed successfully.

3. Sprint Backlog

Review the completed Sprint 2 authentication and authorization work, demonstrate the end-to-end Postman flow, verify both successful and rejected authorization scenarios, confirm the final HTTP status codes, and record the Sprint 2 retrospective with one concrete improvement action for Sprint 3.

4. Definition of Done

- ✓ API behavior matches the demonstrated authentication and authorization scenarios.
- ✓ JWT authentication is demonstrated with successful Patient and Admin login requests.
- ✓ Protected access is demonstrated with successful and rejected requests.
- ✓ Ownership and RBAC rejection cases return 403 Forbidden.
- ✓ Admin-only delete operation returns 204 No Content.
- ✓ Evidence is captured in Postman and included in this Sprint Review document.

5. Postman Demo — Execution Summary

The following seven requests form the recorded Sprint 2 demonstration. The sequence moves from registration and authentication to successful protected access, rejected ownership/RBAC cases, Admin authentication, and successful administrative action.

#	Request	Endpoint	Result	Purpose
1	RegisterPatient	POST /api/auth/register/patient	200 OK	Patient registered successfully.
2	Patient Login	POST /api/auth/login	200 OK	JWT token returned.
3	Own Patient Record	GET /api/patients/16	200 OK	Authenticated patient accessed the allowed patient record.
4	Other Patient Record	GET /api/patients/5	403 Forbidden	Ownership authorization rejected access to another patient record.
5	Patient Delete Attempt	DELETE /api/patients/16	403 Forbidden	Role-based authorization rejected the Patient delete attempt.
6	Admin Login	POST /api/auth/login	200 OK	Admin JWT token returned.
7	Admin Delete Patient	DELETE /api/patients/16	204 No Content	Admin successfully performed the protected delete operation.

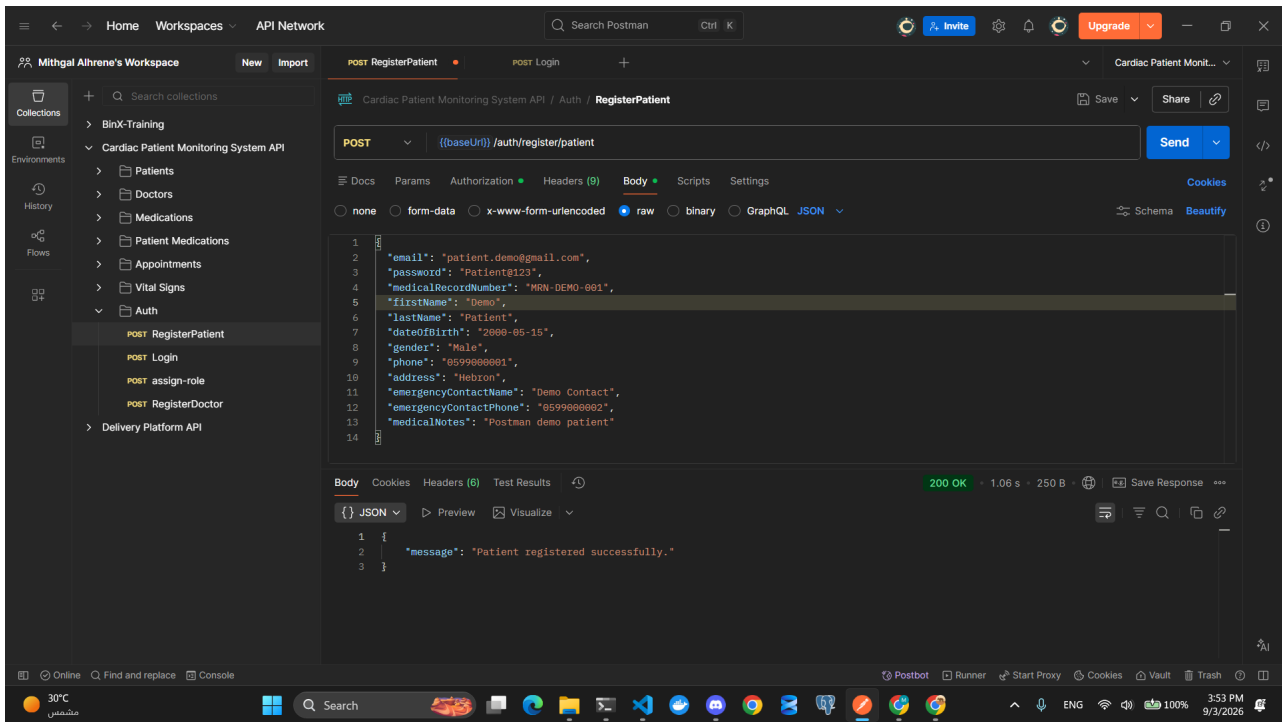
6. Demo Result

Authentication: Verified **Ownership:** Rejection verified **RBAC:** Rejection verified **Admin privilege:** Verified

7. Postman Evidence

01 — RegisterPatient

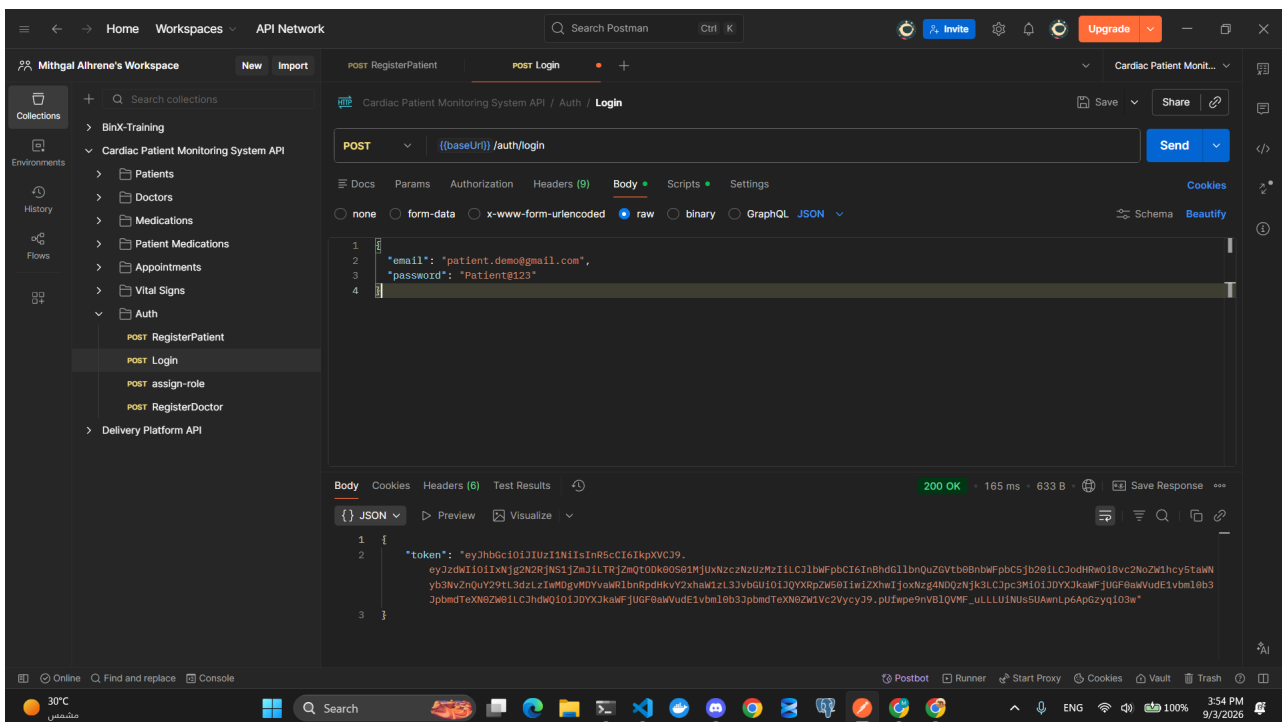
POST /api/auth/register/patient • 200 OK



Patient registered successfully.

02 — Patient Login

POST /api/auth/login • 200 OK

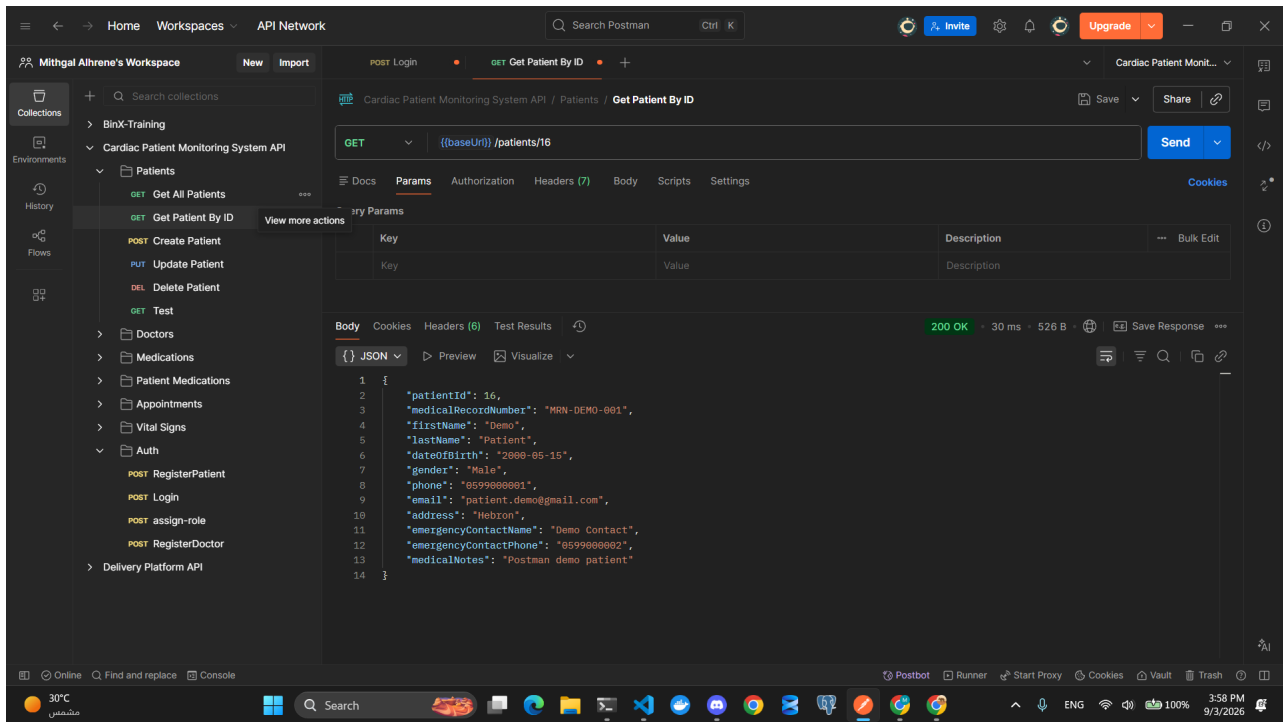


JWT token returned.

7. Postman Evidence

03 — Own Patient Record

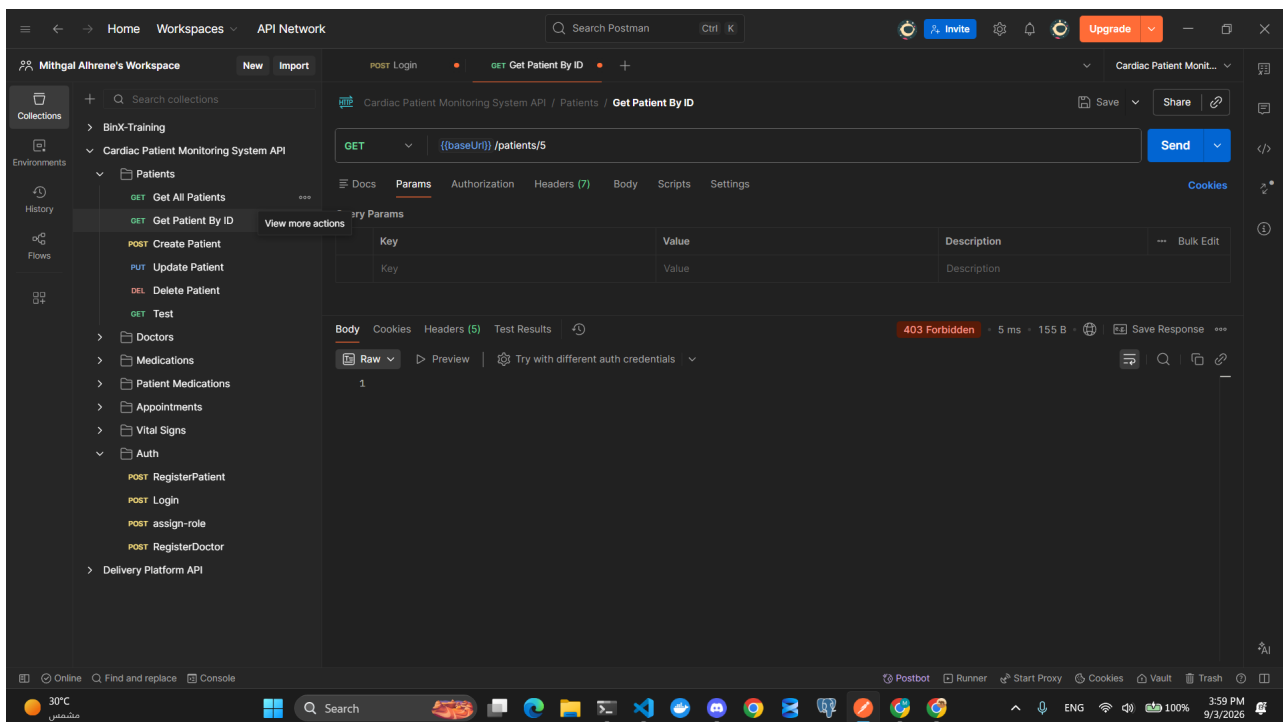
GET /api/patients/16 • 200 OK



Authenticated patient accessed the allowed patient record.

04 — Other Patient Record

GET /api/patients/5 • 403 Forbidden

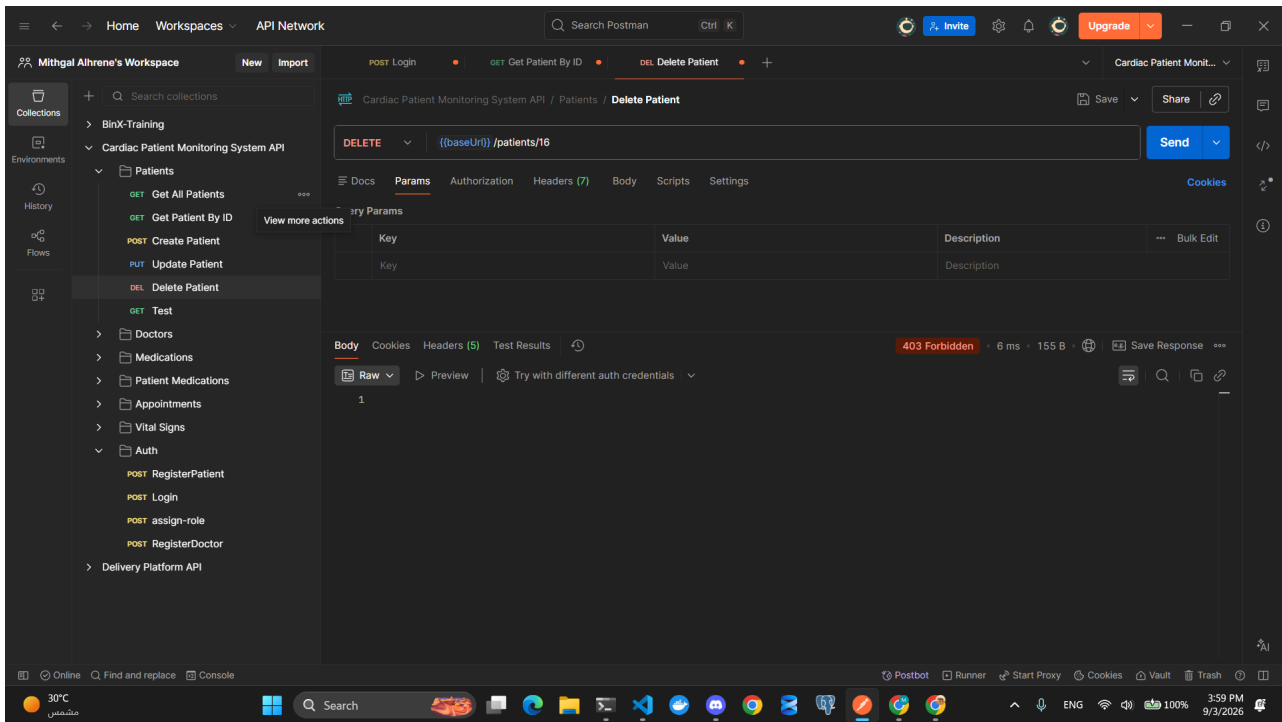


Ownership authorization rejected access to another patient record.

7. Postman Evidence

05 — Patient Delete Attempt

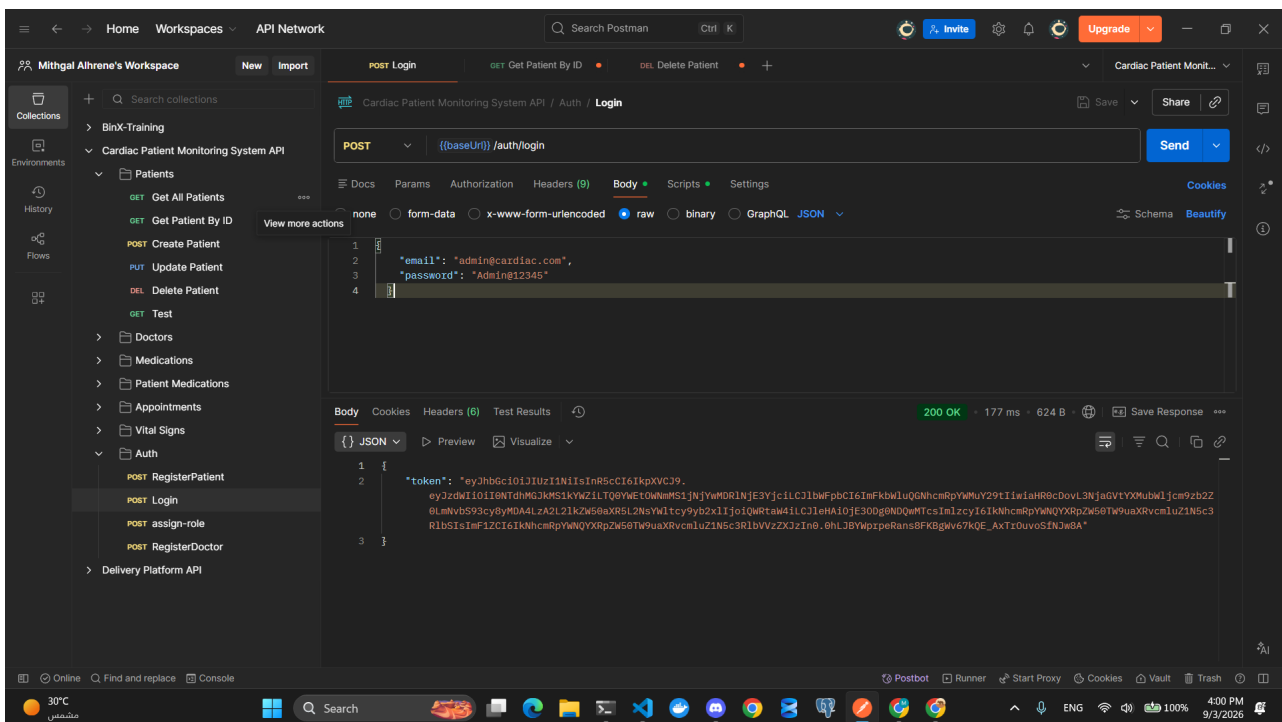
DELETE /api/patients/16 • 403 Forbidden



Role-based authorization rejected the Patient delete attempt.

06 — Admin Login

POST /api/auth/login • 200 OK

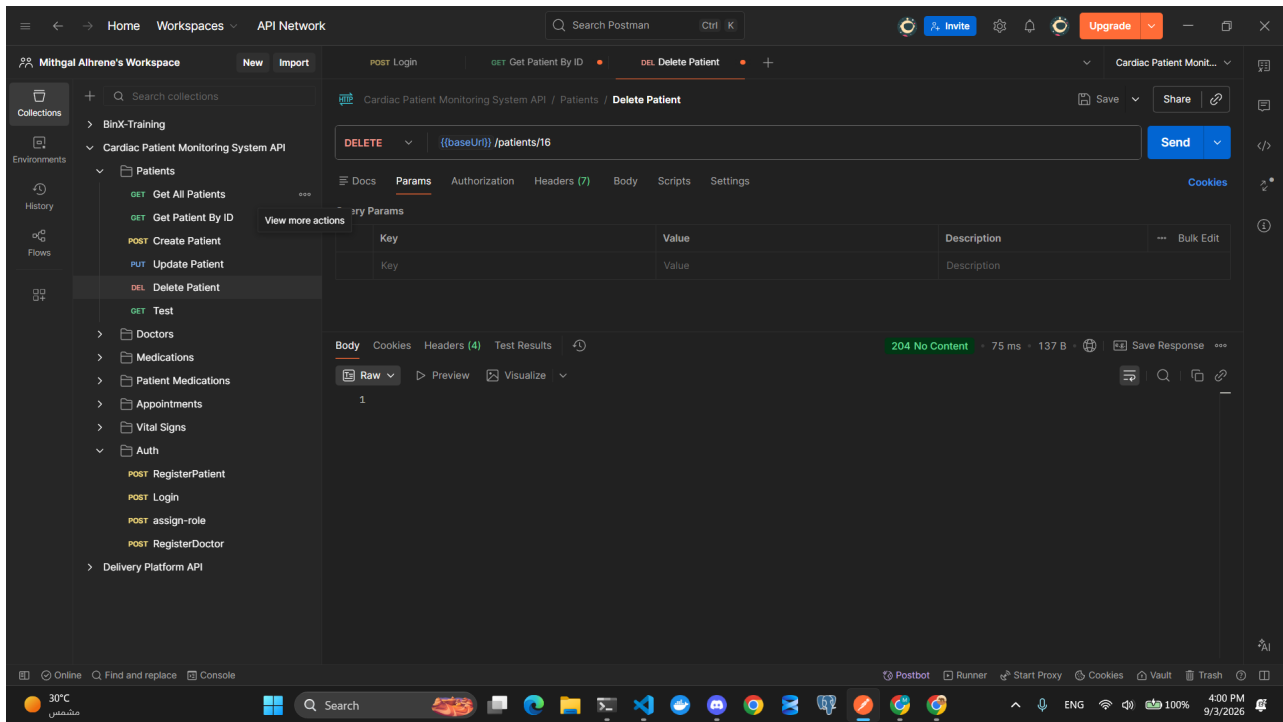


Admin JWT token returned.

7. Postman Evidence

07 — Admin Delete Patient

DELETE /api/patients/16 • 204 No Content



Admin successfully performed the protected delete operation.

8. Sprint 2 Retrospective

8.1. What Went Well

- ✓ Authentication was verified through real registration and JWT login flows.
- ✓ The Postman demo covered both successful and rejected authorization behavior.
- ✓ Resource ownership was demonstrated by rejecting access to another patient's record.
- ✓ RBAC was demonstrated by rejecting a Patient's protected delete operation.
- ✓ Admin authorization was verified through a successful protected delete request.

8.2. What Could Be Improved

Keep the Postman collection and authorization evidence synchronized with implementation changes throughout the sprint, rather than collecting evidence only at the end. Continue validating important authorization rules immediately after implementation.

8.3. Action for Sprint 3

Carry the verification-first approach forward: keep API evidence and targeted tests aligned with each important feature as it is implemented, especially when introducing performance and caching behavior.

9. Day 5 Deliverables

Sprint Review	Completed
Postman Demo	7 requests demonstrated
Authentication	Patient + Admin login verified
Ownership Authorization	403 Forbidden verified
Role-Based Authorization	403 Forbidden verified
Admin Protected Operation	204 No Content verified
Retrospective	Completed

Project Note

Sprint 2 closes with the authentication and authorization layer demonstrated against the real Cardiac Patient Monitoring System API. The evidence intentionally includes rejection cases because correct denial behavior is a core part of authorization validation.